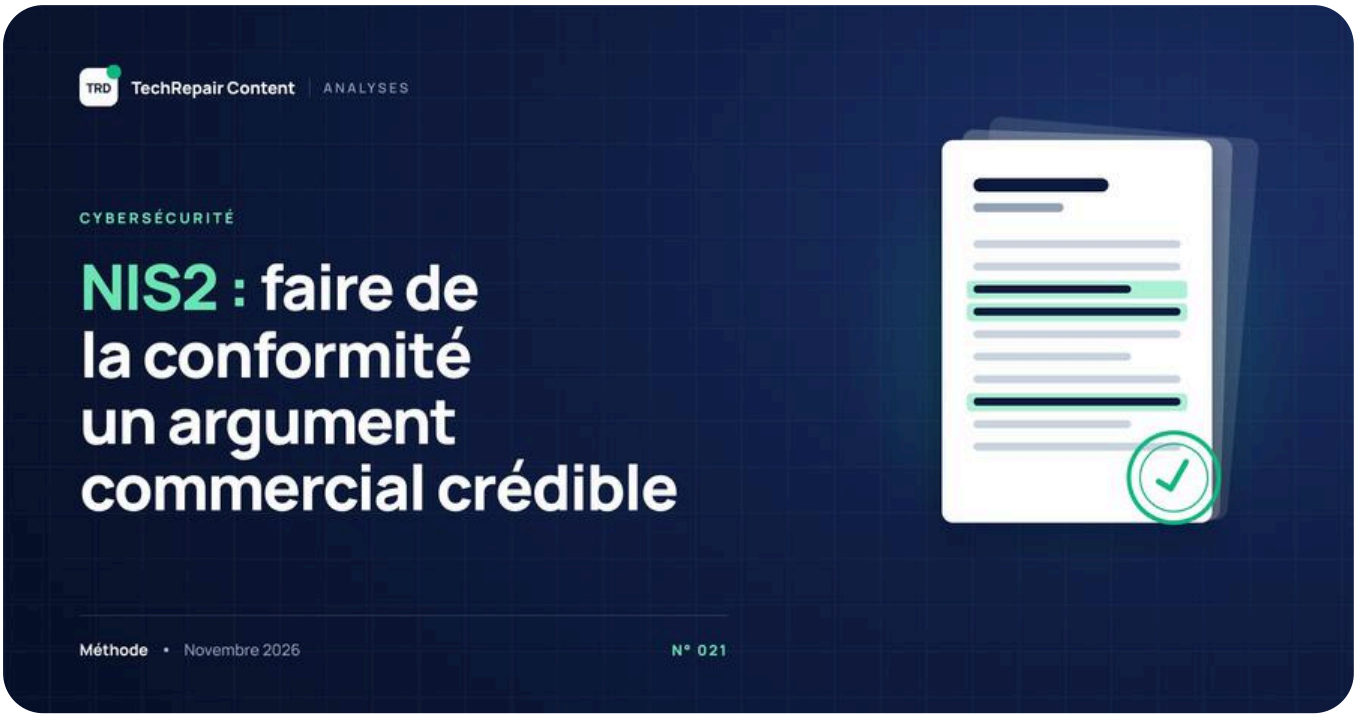
Cybersécurité

Conformité NIS2 : en faire un argument commercial crédible face aux RSSI de vos clients

Rédaction TechRepair Content • Publié le 6 novembre 2026 • ⏱ 12 min de lecture



« Certifié NIS2 » : la formule est tentante pour une plaquette ou une page produit. Elle ne correspond à rien. Aucune certification NIS2 n'existe, et un RSSI qui la lit dans votre proposition commerciale en conclut que votre marketing ne maîtrise pas le sujet qu'il prétend vendre.

La **conformité NIS2** reste pourtant l'un des meilleurs arguments d'un éditeur de cybersécurité ou d'un SaaS qui vend à des entités régulées. Vos clients doivent sécuriser leur chaîne d'approvisionnement : ils vous enverront des questionnaires et compareront vos preuves à celles de vos concurrents. Le fournisseur qui en tire un dossier lisible gagne du temps dans chaque vente. Voici comment le construire, sans promesse fausse ni discours anxiogène.

POINTS CLÉS

- **Le texte vise vos clients, la pression vous atteint :** l'article 21 de la directive impose aux entités régulées de tenir compte des pratiques de cybersécurité de leurs fournisseurs directs.
- **Les acheteurs contrôlent déjà :** selon l'ENISA, 63 % des organisations des secteurs hautement critiques citent l'exigence de normes et de certifications de sécurité parmi leurs contrôles fournisseurs.
- **L'argument crédible est une preuve, pas un label :** à chaque mesure de l'article 21 doit répondre un document vérifiable, daté et attribué à un responsable.
- **Le livre blanc fournisseur sert deux fois :** il répond aux questionnaires avant qu'ils n'arrivent et attire, en recherche, les acheteurs qui préparent leur propre conformité.

Sommaire

1. Questionnaires fournisseurs : la conformité NIS2 arrive par vos clients
2. Votre discours NIS2 tient-il devant un RSSI ?
3. Ce que l'article 21 exige de vos clients, et donc de vous
4. Monter le dossier de preuve en six étapes
5. Dix mesures, dix preuves publiables
6. Plan type du livre blanc fournisseur et réponse réécrite
7. Cinq promesses qui ruinent la crédibilité
8. Ce que le dossier change dans vos cycles de vente
9. Produire le dossier seul ou avec un rédacteur spécialisé
10. Questions fréquentes
11. Sources

1. Questionnaires fournisseurs : la conformité NIS2 arrive par vos clients

Un fournisseur hors du périmètre de NIS2 subit la directive dès qu'il vend à une entité régulée : celle-ci doit évaluer ses prestataires, par questionnaires, audits et clauses contractuelles. L'ANSSI estime

à plus de 10 000 le nombre d'entités visées en France, dans 18 secteurs d'activité : autant d'acheteurs potentiels qui vont interroger leurs fournisseurs.

Les symptômes se reconnaissent vite chez un éditeur de solutions de cybersécurité ou un SaaS B2B : une opportunité bloquée des semaines en « revue sécurité », un tableur interminable que le RSSI remplit seul le soir, des réponses différentes d'un client à l'autre, une page « Sécurité » qui se résume à un cadenas et à la promesse d'un « haut niveau de protection ».

> **63 %**
> citent l'exigence de normes et de certifications imposée aux fournisseurs (ENISA, NIS Investments 2025, décembre 2025)

> **48 %**
> citent des exigences de cybersécurité inscrites dans les contrats fournisseurs (même étude, 1 080 organisations)

> **37 %**
> jugent la gestion du risque fournisseur l'exigence NIS2 la plus difficile à mettre en œuvre (même étude)

L'échantillon de l'ENISA, interrogé entre mai et août 2025 dans les 27 États membres, compte 83 % de grandes entreprises : il décrit surtout les grands comptes, ceux qui envoient les questionnaires les plus longs. Plus d'un tiers d'entre eux peinent sur ce sujet ; le fournisseur qui leur facilite la tâche devient un choix plus sûr. Pour vous, le coût se lit dans le cycle de vente : des heures de RSSI par questionnaire, une signature retardée, un acheteur qui doute.

2. Votre discours NIS2 tient-il devant un RSSI ?

Une heure suffit. Réunissez le responsable marketing, le RSSI et un commercial devant les trois derniers questionnaires reçus et votre page sécurité, puis répondez par oui ou par non.

1. **Vos contenus emploient-ils « certifié NIS2 » ou « conforme NIS2 » sans préciser à quoi ?** Si oui, c'est le premier chantier.
2. **Chaque question récurrente a-t-elle une réponse validée par le RSSI ?**
3. **Chaque affirmation renvoie-t-elle à une preuve** (certificat, rapport d'audit, procédure datée) ?
4. **Vos commerciaux savent-ils ce qui se partage librement et ce qui exige un accord de confidentialité ?**
5. **Votre site répond-il aux recherches de vos acheteurs**, comme « NIS2 fournisseurs », « NIS2 sous-traitant » ou « certification NIS2 », relevées dans les suggestions de Google ?
6. **Savez-vous si vos clients sont eux-mêmes régulés**, et dans quelle catégorie ?

Pour la dernière question, l'ANSSI propose un simulateur sur MonEspaceNIS2 ; les seuils et les secteurs à connaître figurent dans le détail des entreprises concernées par NIS2. Trois « non » ou plus signalent que vos commerciaux vendent la sécurité sans pouvoir la démontrer.

3. Ce que l'article 21 exige de vos clients, et donc de vous

La directive (UE) 2022/2555 (https://eur-lex.europa.eu/eli/dir/2022/2555/oj/fra) du 14 décembre 2022 liste, à son article 21, dix mesures minimales de gestion des risques. Le point d) vise « la sécurité de la chaîne d'approvisionnement, y compris les aspects liés à la sécurité concernant les relations entre chaque entité et ses fournisseurs ou prestataires de services directs ».

Le paragraphe 3 précise ce que l'entité doit regarder chez vous : elle tient compte « des vulnérabilités propres à chaque fournisseur et prestataire de services direct et de la qualité globale des produits et des pratiques de cybersécurité de leurs fournisseurs et prestataires de services, y compris de leurs procédures de développement sécurisé ». Ce passage fournit la trame de votre argumentaire : vulnérabilités, qualité du produit, pratiques, développement sécurisé.

Où en est la loi française

La France n'a pas encore transposé la directive. Le projet de loi Résilience, voté par les sénateurs en mars 2025, revient devant les députés à partir du lundi 9 novembre 2026, selon Silicon. En attendant, l'ANSSI publie depuis le 17 mars 2026 le Référentiel Cyber France (ReCyF), « par défaut non-obligatoire », dont les futurs assujettis pourront se prévaloir en cas de contrôle. C'est la grille que vos clients régulés auront en tête : citez-le avec sa version et sa date.

Et si vous êtes vous-même régulé

Le règlement d'exécution (UE) 2024/2690 du 17 octobre 2024 fixe des exigences techniques pour plusieurs catégories, dont les fournisseurs de services d'informatique en nuage, de services gérés et de services de sécurité gérés. Ces fournisseurs parlent alors de leur propre conformité : même méthode, preuves plus exigeantes.

> **Il n'existe pas de « certification NIS2 ».**
>
> La directive n'est pas une norme certifiable. Son article 24 permet seulement aux États membres d'imposer des produits, services ou processus TIC certifiés dans le cadre de schémas européens de certification de cybersécurité. Bureau Veritas, organisme de certification, le résume : « A NIS2 certification does not currently exist ». Citez plutôt vos certifications réelles, ISO/IEC 27001 par exemple, et les mesures qu'elles couvrent.

4. Monter le dossier de preuve en six étapes

Le dossier de preuve rassemble ce qu'un acheteur doit savoir de votre sécurité. Comptez quatre à six semaines, piloté par le marketing et validé par le RSSI.

1. **Collecter les questionnaires (semaine 1, marketing et avant-vente).** Fusionnez les dix derniers questionnaires reçus dans un tableur et regroupez les questions par mesure de l'article 21 ; les doublons montrent les vraies attentes.
2. **Inventorier les preuves existantes (semaine 1, RSSI, deux heures).** Certificats, rapports d'audit, politiques, procédures, clauses types : notez pour chacun la date et le périmètre.
3. **Classer en trois niveaux de diffusion (semaine 2, RSSI et juridique).** Public, sur demande, sous accord de confidentialité. Un rapport de test d'intrusion complet reste confidentiel ; sa date, le type de test et l'existence d'un plan de correction peuvent être publics.
4. **Rédiger la bibliothèque de réponses (semaines 2 et 3, rédacteur et RSSI).** Une réponse type par question récurrente, factuelle, datée, avec sa preuve.
5. **Publier la partie publique (semaines 3 et 4, marketing).** Une page sécurité structurée par mesure, puis un livre blanc fournisseur qui explique votre approche. Rédigé pour la recherche, un livre blanc NIS2 attire aussi des liens d'intégrateurs et de partenaires, nourrit des articles satellites, une mesure par article, capte l'e-mail des acheteurs qui le téléchargent et donne aux assistants IA un document de référence à citer.
6. **Former les commerciaux (semaine 5, une heure)** : ce qu'ils disent, ce qu'ils envoient, quand ils passent la main au RSSI.

Critère de décision pour le format : si vos clients vous envoient surtout des questionnaires standardisés, commencez par la bibliothèque de réponses ; s'ils vous découvrent en ligne, commencez par la page sécurité et le livre blanc.

5. Dix mesures, dix preuves publiables

Ce tableau associe chaque mesure de l'article 21, paragraphe 2, à une preuve qu'un fournisseur peut produire et au contenu qui la porte. Adaptez les validateurs, entre parenthèses, à votre organisation.

MESURE	PREUVE À PRODUIRE	SUPPORT
a) Analyse des risques et politique de sécurité	Résumé de la politique, date de dernière revue, sponsor à la direction	Page sécurité (RSSI)
b) Gestion des incidents	Délai d'alerte des clients, canal, rôle du contact sécurité	Page sécurité et annexe contractuelle (RSSI et juridique)
c) Continuité et sauvegardes	Objectifs de reprise, date du dernier test de restauration	Dossier sur demande (CTO)
d) Fournisseurs directs	Liste de vos propres sous-traitants critiques et critères de choix	Page publique des sous-traitants (RSSI et achats)
e) Développement et vulnérabilités	Politique de divulgation, délai de correction par criticité	Page publique et fichier security.txt (CTO)
f) Évaluation de l'efficacité	Dates et périmètres des audits et tests d'intrusion	Dossier confidentiel (RSSI)
g) Cyberhygiène et formation	Fréquence des formations, part des équipes formées	Livre blanc (RH et RSSI)
h) Chiffrement	Chiffrement au repos et en transit, gestion des clés	Documentation technique (CTO)
i) Ressources humaines, accès, actifs	Revue des droits, procédure de départ, inventaire	Bibliothèque de réponses (RSSI)
j) MFA et communications	Comptes couverts par la MFA, options proposées	Page produit et documentation (Produit)

Chaque ligne se lit aussi comme un argument commercial vérifiable : « nos clients reçoivent l'alerte sous un délai contractuel » convainc davantage qu'une promesse de sécurité renforcée. La crédibilité technique attendue par ce lectorat, et les formulations qui la font perdre, sont détaillées dans la façon de convaincre un RSSI par le contenu.

6. Plan type du livre blanc fournisseur et réponse réécrite

Le livre blanc fournisseur explique votre approche à un acheteur qui découvre votre entreprise. Douze à seize pages suffisent, sur ce plan.

1. **Ce que NIS2 demande à vos clients**, en une page, avec la date de l'état du droit.
2. **Votre périmètre** : produit, hébergement, sous-traitants, ce qui relève de vous et ce qui relève du client.
3. **Les dix mesures, une section chacune** : votre pratique, la preuve disponible, son niveau de diffusion.
4. **Responsabilité partagée** : les réglages que le client doit activer lui-même (MFA, journalisation, rétention).
5. **Notification des incidents** : délais, canal, contenu du premier message.
6. **Feuille de route** : ce qui est en cours, avec des échéances que vous tiendrez.
7. **Annexe** : correspondance avec ISO/IEC 27001 ou le ReCyF, glossaire, contact sécurité.

Exemple avant / après, rédigé pour cet article

Question reçue : « Décrivez votre gestion des incidents de sécurité et vos délais de notification. »

Avant : « Nous prenons la sécurité très au sérieux et disposons de processus robustes, conformes aux meilleures pratiques et à NIS2. »

Après : « Tout incident qui affecte les données ou la disponibilité du service d'un client lui est signalé par e-mail, auprès du contact sécurité désigné au contrat, dans un délai de [X] heures après sa qualification. Ce premier message indique la nature de l'incident, les données concernées et les mesures prises. Notre procédure a été révisée le [date] ; le dernier exercice de crise date du [date]. Un extrait de la procédure est disponible sous accord de confidentialité. »

La seconde version ne revendique aucune conformité : elle donne à l'entité régulée de quoi tenir ses propres délais de notification. Les crochets se remplissent avec vos valeurs réelles.

7. Cinq promesses qui ruinent la crédibilité

- **« Certifié NIS2 ».** La certification n'existe pas ; écrivez quelle norme vous détenez et ce qu'elle couvre.
- **« 100 % conforme NIS2 ».** Un fournisseur ne peut pas rendre son client conforme : il contribue à sa conformité. Et tant que la transposition française reste en discussion, une conformité totale à des obligations nationales non fixées ne se démontre pas.
- **Le compte à rebours des amendes.** Brandir les plafonds de sanction relève du marketing de la peur, que les RSSI repèrent aussitôt.
- **Les réponses copiées d'un modèle.** Elles ne résistent pas à la première question de relance.

- **Les preuves sans date.** Un test d'intrusion « récent » sans mois ni année ne prouve rien. Le même principe vaut pour les références clients : une étude de cas anonymisée reste crédible si chaque résultat est daté et vérifiable.

8. Ce que le dossier change dans vos cycles de vente

Le dossier fonctionne s'il raccourcit la revue sécurité et si les commerciaux s'en servent sans solliciter le RSSI. Aucun seuil universel n'existe, tant la longueur des questionnaires varie : mesurez les dix derniers questionnaires, puis comparez au bout d'un trimestre.

- **Délai de retour d'un questionnaire**, de la réception à l'envoi complet : l'indicateur principal.
- **Part des questions traitées depuis la bibliothèque**, sans rédaction nouvelle : elle doit progresser à chaque questionnaire.
- **Heures du RSSI consacrées aux questionnaires.**
- **Opportunités bloquées en revue sécurité** au-delà de trente jours.
- **Téléchargements du livre blanc par des comptes cibles** et rendez-vous obtenus ensuite.

9. Produire le dossier seul ou avec un rédacteur spécialisé

L'inventaire et la classification des preuves restent internes : seul votre RSSI connaît vos pratiques. La rédaction bute sur le temps et sur la double exigence d'exactitude technique et de lisibilité commerciale. Faites seul si votre RSSI dispose de deux journées pour relire et si un membre de l'équipe marketing écrit déjà des contenus techniques. Faites-vous accompagner si les questionnaires bloquent plusieurs opportunités par trimestre, si le livre blanc doit aussi servir au référencement, ou si vos contenus actuels promettent ce que vous ne pouvez pas prouver. La validation finale reste au RSSI.

Questions fréquentes

Un fournisseur d'une entreprise soumise à NIS2 est-il concerné ?

Indirectement, oui : l'entité régulée doit tenir compte des pratiques de cybersécurité de ses fournisseurs directs et vous demandera des preuves, même si vous êtes hors du périmètre de la loi.

Existe-t-il une certification NIS2 ?

Non. NIS2 est une directive, pas une norme certifiable. Une certification ISO/IEC 27001 aide à démontrer une partie des mesures, mais aucun label « NIS2 » officiel n'existe.

NIS2 ou ISO 27001 : quelle différence pour un fournisseur ?

ISO/IEC 27001 est une norme volontaire et certifiable ; NIS2, une obligation légale pour vos clients régulés. Votre certificat sert de preuve si vous montrez quelles mesures de l'article 21 son périmètre couvre.

Que contient un questionnaire fournisseur NIS2 ?

Le plus souvent, des questions calquées sur les dix mesures de l'article 21, des délais d'alerte en cas d'incident à l'authentification multifacteur.

Quand la loi NIS2 s'appliquera-t-elle en France ?

La date n'est pas fixée : le projet de loi Résilience revient devant les députés le 9 novembre 2026, puis des décrets préciseront les obligations. Les questionnaires de vos clients n'attendent pas.

En résumé

NIS2 devient un argument commercial le jour où chaque affirmation de vos contenus renvoie à une preuve datée. Rassemblez vos questionnaires, classez vos preuves, rédigez une réponse type par mesure, puis publiez une page sécurité et un livre blanc qui répondent avant qu'on vous interroge. Pour transformer votre documentation de sécurité en livre blanc fournisseur exact et lisible par un acheteur, demandez un diagnostic de vos contenus NIS2.

Faire auditer vos contenus NIS2 →

Sources

1. Parlement européen et Conseil, « Directive (UE) 2022/2555 du 14 décembre 2022 (directive SRI 2) », JO L 333 du 27 décembre 2022, articles 21 et 24. eur-lex.europa.eu
2. Commission européenne, « Règlement d'exécution (UE) 2024/2690 du 17 octobre 2024 ». eur-lex.europa.eu
3. ENISA, « NIS Investments 2025 », 8 décembre 2025. enisa.europa.eu
4. ANSSI, « La directive NIS 2 » (présentation du ReCyF), consulté le 6 novembre 2026. cyber.gouv.fr
5. ANSSI, actualité du 18 mars 2026 annonçant la publication du ReCyF. cyber.gouv.fr
6. ANSSI, « Plaquette NIS 2 », version 1.0, mars 2024. monespacenis2.cyber.gouv.fr
7. Silicon, article du 5 novembre 2026 sur la réinscription du projet de loi Résilience à l'Assemblée nationale. silicon.fr
8. Bureau Veritas, « Clarifying the confusion around “NIS2 certification” », consulté le 6 novembre 2026. bureauveritas.com

À lire aussi

CYBERSÉCURITÉ

Marketing cybersécurité : convaincre un RSSI sans jouer sur la peur

CYBERSÉCURITÉ

NIS2 en France : entreprises concernées et plan d'action avant la loi Résilience

CYBERSÉCURITÉ

Identités Non-Humaines : sécuriser l'explosion des agents IA

Lire l'article · 12 min

Lire l'article · 12 min

Lire l'article · 16 min